Standar Arsitektur Keamanan Tingkat Tinggi Informasi (SAKTTI)

Introduction to Standard High Grade Information Security Architecture

SAKTTI Objective

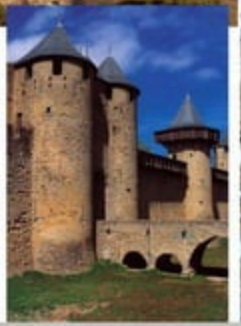
SAKTTI

is an architecture to build an integrated "digital fortress" system which consist of people,administrative, technology and physical controls that enforce the consistency of information security strategy.

SAKTTI's Biggest Challenge: To Change The Mindset

"I feel convenience if...
I use the **good** safety belt and helmet **properly** and
the car has the **effective** breaking system to go fast !"

The Digital Fortress, an illustration…

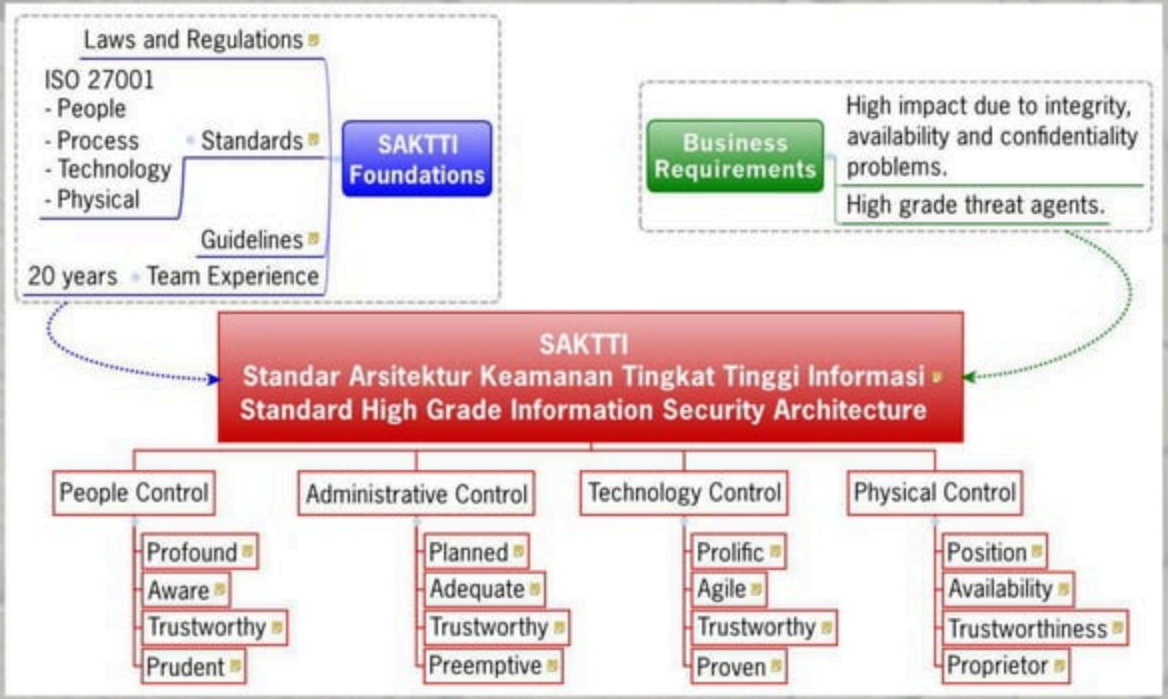


SAKTTI Control Principles

Balanced between preventive, detective and corrective controls in all information life cycle:

- White List Approach
- Defense in Depth
- Integrity Assurance
- Least Privilege
- Separation of Duties
- End-to-End Security
- Full Encryption
- System Partitioning
- System Redundancy
- Backup and Restore

SAKTTI Components



Information Security Concept

SAKTTI - Information Security Concepts.odp

SAKTTI Technology Controls
People Security

- Integrity Assurance
  - People integrity must be ensured though background checking, monitoring and audit.
- Competencies
  - People must be aware, prudent and have profound information security knowledge to secure the information.
- Protection
  - People must be protected, especially under dourest.

SAKTTI Technology Controls
Administrative Security

- **Fully comply with laws and regulations**
- **Fully conform with international standards, such as:**
  - ISO/IEC 22000 Business Continuity Management (BCM)
  - Payment Card Industry Data Security Standard (PCI DSS)
  - Baseline Requirements for the Issuance & Management of Publicly-Trusted Certificates
  - TIA-942 Data Center Standards
- **Risk Assessment Methodology includes threat agent.**
- **Appropriate Information Security Classification**
  - 4 categories of business impact: Financial, Reputation, Legal and Safety.
    - *Khusus untuk penyelenggara negara: IPOLEKSOSBUDHANKAM*
  - 4 levels of classification: Level 1, Level 2, Level 3, Level 4
  - Aspects: Integrity, Availability, Confidentiality
- **Secure Change Management**

SAKTTI Technology Controls
Technology Security: Zoning and Connections

5 Jenis Koneksi Fisik Terenkripsi

- Koneksi **Pengguna Mobile** ke **DC** via **Internet**
- Koneksi **Lokasi Remote** ke **DC** via **Internet**
- Koneksi **DC** to **DC** via **Internet**
- Koneksi via **WAN** (FO, MPLS, VSAT)
- Koneksi via **LAN**

Lingkup Pengamanan

SAKTTI Technology Controls
Technology Security: Data Encryption

- Media penyimpan harus dienkripsi.
  - Media penyimpan didalam perangkat server harus dilindungi menggunakan enkripsi hardware.
- Seluruh paket jaringan pada koneksi fisik diluar dan antar Zona harus selalu dalam bentuk terenkripsi.
- Seluruh paket jaringan harus dianalisa dan difilter dalam kondisi clear text oleh firewall aplikasi dan/atau IDS saat melalui Application Cross Area di Zona Tengah.
- Seluruh paket jaringan didalam Zona Dalam (Area 0, Area Aplikasi, Area Database dan Area Server Farm Connectivity (SFC) harus dalam bentuk clear text agar dapat dianalisa oleh IDS.

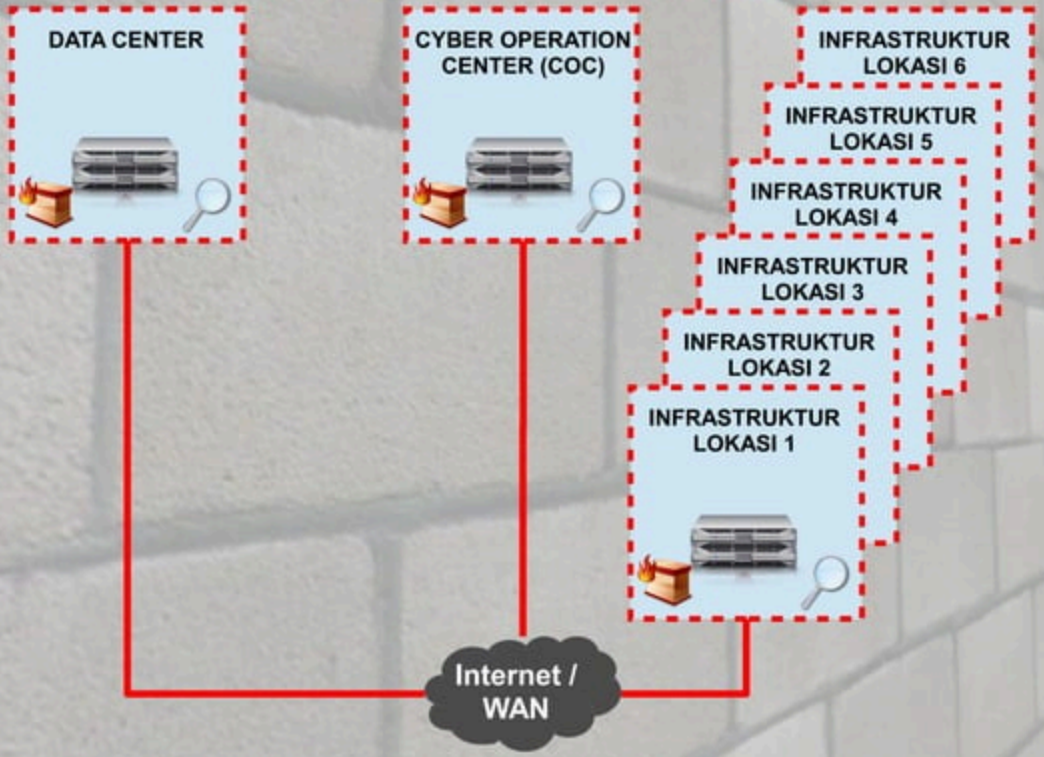
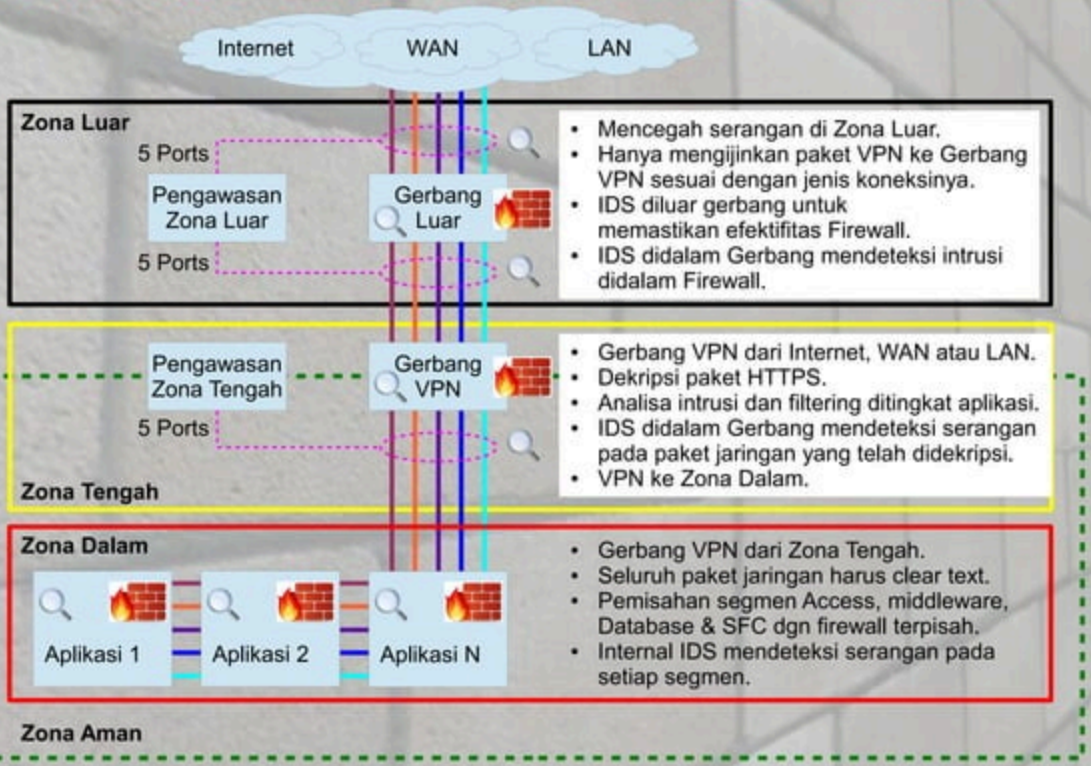
SAKTTI Technology Controls
Technology Security: Network

- **Physical Separation and Network Segmentation**
  - Jaringan fisik dibagi secara vertikal kedalam Zona Luar, Zona Tengah dan Zona Dalam.
  - Setiap sub zona harus menggunakan firewall terpisah.
  - Setiap jenis koneksi Internet, WAN dan LAN harus menggunakan Sub Zona terpisah.
  - Segmentasi jaringan harus dapat membentuk lalu lintas jaringan yang terpola berdasarkan sensitifitas dan tingkat risiko.
  - Pemisahan infrastruktur aplikasi (berbeda Zona Dalam) berdasarkan klasifikasi keamanan informasi dan berdasarkan pengelompoka risiko (jenis aplikasi, kelompok pengguna, dll).
  - Network switch digunakan jika terdapat beberapa Zona Dalam.

SAKTTI Technology Controls
Technology Security: Network

- **Multi Layers Network Detection and Prevention**
  - Setiap segmen jaringan harus dipisahkan oleh firewall.
  - Filtering dari Zona Luar hingga ke Area 0 (Core) didalam Zona Aplikasi harus menggunakan 2 firewall (sistem operasi dan aplikasi) yang berbeda.
  - Setiap segmen jaringan diluar dan didalam Zona harus diawasi oleh IDS.
  - Eksploitasi kelemahan kritis dan backdoor pada salah salah zona atau segmen jaringan harus dapat dideteksi dan dicegah.
- **IP Address Allocation**
  - Pengelompokan terstruktur yang mudah dimengerti, diingat dan diidentifikasi secara visual terutama untuk keperluan pengawasan dan analisa serangan.

SAKTTI Technology Controls
Technology Security: Secure Connection



SAKTTI Technology Controls
Technology Security: Network Diagram Level-0